DFD Level 1 — Explanation

CloudGuard IoT | Team ZeroTrace | Companion to `03-System-Behavior/DFD-Level-1.png`

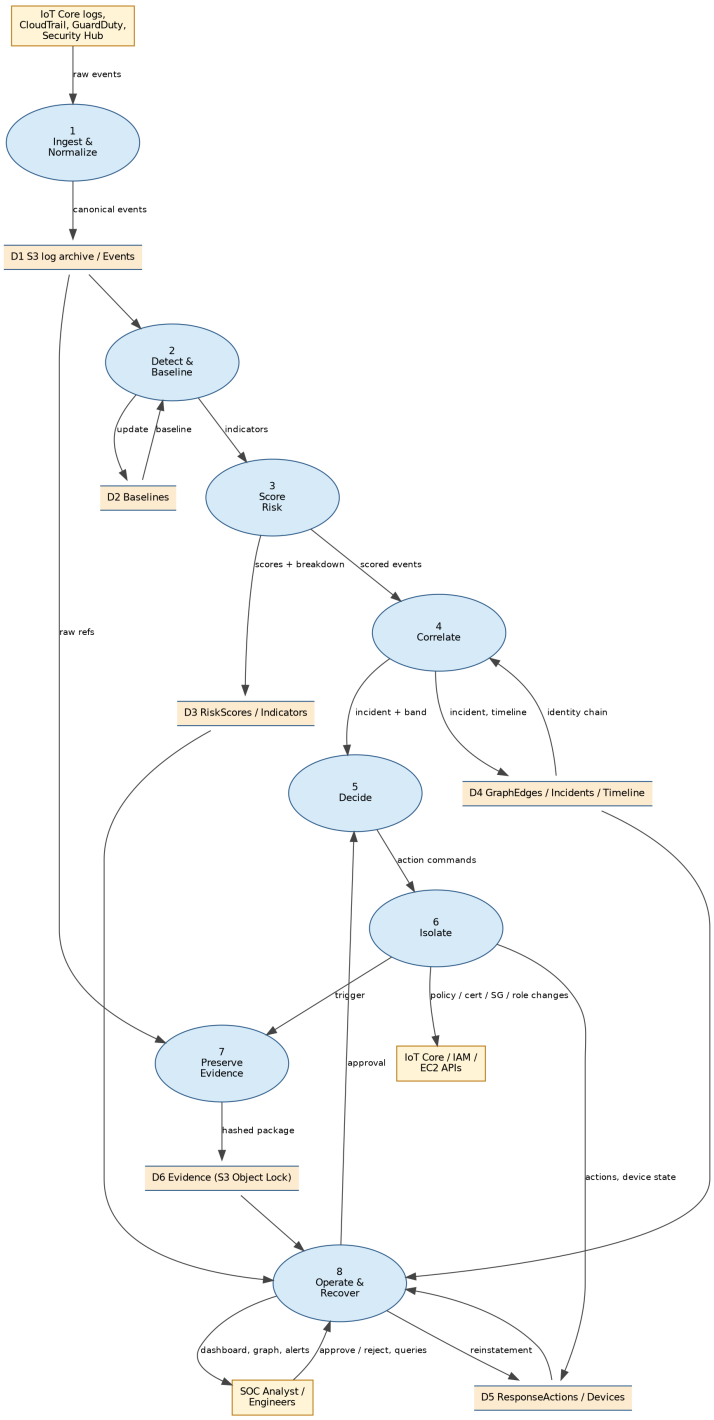


Figure: DFD Level 1

1. Purpose

Level 1 opens up the single process of the context diagram and shows how data moves inside CloudGuard IoT. It decomposes the system into eight processes (P1–P8), six groups of data stores (D1–D6) and three external entities. It follows the platform workflow: **Detect → Risk Score → Correlate → Decide → Isolate → Investigate → Recover**.

2. Notation

Symbol	Meaning
Ellipse (P1–P8)	Process that transforms data
Open box (D1–D6)	Data store (DynamoDB table group or S3 bucket)
Rectangle	External entity
Labelled arrow	Data flow

3. External Entities

Entity	Description
IoT Core logs, CloudTrail, GuardDuty, Security Hub	Telemetry and findings sources. Device MQTT activity arrives as IoT Core logs
SOC Analyst / Engineers	Humans who approve isolation, query the system and run recovery
IoT Core / IAM / EC2 APIs	The enforcement targets that receive isolation changes

4. Processes

ID	Process	Inputs	Outputs	What it does
P1	Ingest & Normalize	Raw events from IoT Core logs, CloudTrail, GuardDuty, Security Hub	Canonical events to D1	Converts every event into one canonical schema and attaches it to an entity and its identity chain
P2	Detect & Baseline	Canonical events (D1), baselines (D2)	Indicators to P3; baseline updates to D2	Applies the IoT and cloud detection rules and compares behavior (rate, topic set, payload size, connect frequency, destinations) with each device's baseline
P3	Score Risk	Indicators from P2	Scores and per-indicator breakdown to D3; scored events to P4	Computes the 0–100 weighted, time-decayed risk score and stores why it was given
P4	Correlate	Scored events, identity chain (D4)	Incident and timeline to D4; incident with band to P5	Joins IoT and cloud events on the same identity chain inside the correlation window, applies the cross-domain bonus, opens or updates one incident
P5	Decide	Incident with band; analyst approval from P8	Action commands to P6	Applies the band and the mode (dry-run, manual, auto): Critical is automatic, High waits for approval
P6	Isolate	Action commands	Policy, certificate, security group and role changes to the AWS APIs; actions and device state to D5; trigger to P7	Quarantines the device and restricts the cloud identity; every action is idempotent, reversible and logged
P7	Preserve Evidence	Trigger from P6; raw references from D1	Hashed evidence package to D6	Copies logs, findings, policy snapshots and the action log to protected storage and records SHA-256 hashes
P8	Operate & Recover	Analyst approvals and queries; reads from D3, D4, D5, D6	Dashboard, graph, alerts to the analyst; approval to P5; reinstatement to D5	Serves the dashboard and API, and runs the reinstatement and certificate rotation workflow

5. Data Stores

ID	Contents	Technology	Written by	Read by
D1	Canonical events, raw log archive	DynamoDB (Events) + S3 log archive	P1	P2, P7
D2	Per-device behavioral baselines	DynamoDB (Baselines)	P2	P2
D3	Risk scores and indicator breakdowns	DynamoDB (RiskScores, Indicators)	P3	P8
D4	Graph edges, incidents, timeline	DynamoDB (GraphEdges, Incidents, Timeline)	P4	P4, P8
D5	Response actions (audit log) and device state	DynamoDB (ResponseActions, Devices)	P6, P8	P8
D6	Evidence package and hash manifest	S3 evidence bucket with Object Lock	P7	P8

6. Data Flow Walkthrough

The reference attack: a compromised device floods MQTT and touches topics outside its policy, while its related cloud role enumerates IAM.

1. **Raw events** enter P1, which stores **canonical events** in D1.
2. P2 reads D1 and the device's **baseline** from D2, finds the rate spike, the unauthorized topic access and the IAM enumeration, and sends **indicators** to P3. It also **updates** the baseline.
3. P3 computes the score, stores the **scores and breakdown** in D3 and passes **scored events** to P4.
4. P4 reads the **identity chain** from D4, sees IoT and cloud evidence on the same chain, applies the cross-domain bonus, and writes one **incident and timeline** to D4. The score reaches 87.
5. P4 sends the **incident and band** to P5. P5 sees Critical and issues **action commands** to P6.
6. P6 sends **policy, certificate, security group and role changes** to the AWS APIs, writes **actions and device state** to D5, and **triggers** P7.
7. P7 reads **raw references** from D1 and writes the **hashed package** to D6.
8. P8 reads D3–D6 and returns the **dashboard, graph and alerts** to the analyst.
9. In the High-band case, the analyst's **approve / reject** flows through P8, and the **approval** reaches P5, which then continues at step 5.
10. After investigation, P8 writes the **reinstatement** to D5 (new certificate, device back to ACTIVE).

7. Balancing with Level 0

Level 1 must carry the same inputs and outputs as Level 0.

Level 0 flow	Where it appears in Level 1
MQTT telemetry, Logs, findings	Raw events into P1
Isolation commands	P6 to AWS APIs
Alerts, incidents, graph	P8 to analyst
Approve / reject, queries	Analyst to P8
KPIs, response history	Produced by P8 from D3–D5
Quarantine status	Produced by P8 from D5
Onboarding, rotation	Handled by P8 (recovery workflow) and written to D5
Rules, thresholds	Configuration of P2, P3 and P5 (change-controlled)

To keep the diagram readable, the Level 0 entities IoT Security Engineer, Cloud Security Engineer, SOC Analyst and Security Manager are grouped into one "SOC Analyst / Engineers" box, and the devices are represented by their IoT Core logs. The KPIs, quarantine status, onboarding and rule-change flows are therefore described in this table rather than drawn as separate arrows.

8. Design Notes

- **Separation of duties:** P6 holds the only write access to isolation APIs, and its role is limited to quarantine actions (least privilege).
- **Explainability:** P3 always writes the breakdown to D3, so any score can be explained later through P8.
- **Integrity:** P7 writes to an Object Lock bucket, so evidence cannot be altered after collection.
- **Failure handling:** each process runs as a Lambda with retries and a dead-letter queue, so a failed step is visible rather than silently lost.